Sunspire

netsiege one

“Sunspire” is the scenario for netsiege one, the first trial run of the netsiege competition

Narrative

On a remote island, far away from most of the world, is the solarpunk city of Sunspire. A radiant forest-city that is composed of ecologically-sustainable towns that blend technology and nature. Every home, garden, and communal hall is powered by a masterfully engineered computing network that provides the essential services necessary for the
society to function.

For the first time in its history, Sunspire would like to invest heavily into cybersecurity and kickstart its cyber servants program. A group responsible for ensuring the computer systems essential to Sunspire could never be destroyed. To fairly choose these newest civil servants, Sunspire is holding a tournament of strengths.

Sunspire has invited world-class cybersecurity teams from around the world to compete against each other for the chance to become the very first members of the Sunspire cyber servants program. Each team will compete against each other to break into sunspire's network, stabilize it, and defend it from their competitors.

Personnel

Axel: software steward @ sunspire
Fern: systems steward @ sunspire
Mason: manufacturing engineer @ sunspire

netsiege 1.1 (netsiege one round one)

solaris | ubuntu server 24.04	
description	
Solaris is an old file sharing server. It represents reliability, stability, warmth, and a touch of nostalgia of what used to be.	
initial access	**privesc**
Samba (anonymous SMB): Contains user password in backup.zip **Basic PHP website**: Arbitrary file upload	**SUID**: base64 binary base64 binary is given SUID as a misconfiguration by previous sysadmin who thought they needed it for the reporting script to work properly. **Cronjob**: /usr/local/bin/solaris-report.sh solaris-report.sh is responsible for base64 encoding the last 10 auth.log lines and placing it in a log file (/var/log/auth-store.log)
services	
Samba SMB (anonymous share) Apache serving PHP website w/ arbitrary file upload OpenSSH Server	
users	
solaris:solar-paneL321 **root**:Ag9G61RF **ops**:9ksP311p	
scoring	
Services: Website, SSH, SMB **Files:** /root/ctrl.txt, /home/solaris/ctrl.txt, /opt/starfall/ctrl.txt	
lateral movement	
SSH Keys → starfall: SSH keys are available to a low-privilege user on *starfall*	

orbital | windows server 2022

description

Orbital is a Windows file processing and scheduling server used by Sunspire's computing operations team.

initial access	**privesc**
Anonymous SMB share: Stores MD5 hashes but is public for some reason. One of the MD5 hashes is for the orbital user. If cracked, can be used to RDP in. **Open MSSQL Server:** Xp_cmdshell enabled, blank password for sa	**Scheduled Task (SolarTelemetry):** A SYSTEM-level scheduled task (SolarTelemetry) executes a PowerShell script located at C:\Sunspire\telemetry.ps1. The script file is world-writable, enabling a user to replace its contents and achieve code execution as SYSTEM. **Unquoted Service Path (SunSpire Backup Agent):** The SunSpire Backup Agent service uses an unquoted service path: C:\Program Files\SunSpire Backup\backup.exe. Attackers can place a malicious C:\Program.exe to escalate privileges to SYSTEM.

services

SMB (anonymous share)
Open MSSQL Server

users

orbital:securepassword
Administrator:5EVB7Zmp
ops:9ksP311p

scoring

Services: SMB, MSSQL
Files: C:\Administrator\ctrl.txt, C:\Users\orbital\ctrl.txt

lateral movement

.rdp → helios: RDP file to low-privilege user (helios) on *helios*

starfall | ubuntu 24.04

description

Starfall is a beautiful creation by our systems stewardess Fern. The same way the stars will never fall, neither will Sunspire's most critical services. Starfall is a gateway to much more…

initial access	**privesc**
Command Injection: Command injection via exposed API endpoint for "cat." **Weak/Guessable Password**: Insecure password for starfall user.	None needed, starfall is part of the sudoers group

services

Exposed API service (:5000)
OpenSSH Server

users

starfall:starfall
root:qi6AJZin
ops:9ksP311p

scoring

Services: API, SSH
Files: /home/starfall/ctrl.txt, /var/www/ctrl.txt

lateral movement

(– Round 2 –)
Starfall → Forge w/ SSRF
Internal API listening on 127.0.0.1:5001
Endpoint that utilizes a certain *user_agent* and token that can be found in a *.env* file.
This is a way to gain a password for an unprivileged user on a round 2 machine (forge)

helios | windows server 2022

description

Helios is a Windows server that is primarily used for administration tasks across the network. Just as how Helios takes his chariot across the sky, this server allows sunspire network stewards to walk across the network.

initial access	privesc
Anonymous VNC VNC is enabled for “helios” user, with authentication disabled. **.rdp file from orbital** Utilize .rdp file found in orbital to log in. **Same password for “pyre” user as “pyre” user on pyre server:** Password reuse **Weak/Guessable password for helios user:** Password of “password” for helios user	**Powershell History:** Powershell history has the Administrator’s password in a net user command. **Environment variable:** Environment variables for the system has the Administrator’s password for some reason.

services

VNC

users

pyre:h1ewFWZG
helios:password
Administrator:BTw5hYqi
ops:9ksP311p

scoring

Services: VNC
Files: C:\Administrator\ctrl.txt, C:\Users\helios\ctrl.txt

lateral movement

SSH Keys → starfall: SSH keys are available to a low-privilege user on *starfall*

netsiege 1.2 (netsiege one round two)

forge | ubuntu 24.04	
description	
A forge to develop new software for sunspire.	
initial access	**privesc**
SSRF (from starfall): API with a vulnerable endpoint that can leak a password by displaying all environment variables. This endpoint is only accessible with the correct token and user_agent. It will leak the root password in doing so. **Git**: Git repository hosted via HTTP. Clone repository and check git history for forge user password.	Git pre-commit hooks that can be edited to run a command on a push. * Not necessary if you gain access through the SSRF.
services	
Exposed API service (:5001) OpenSSH Server	
users	
forge: h1ewFWZG **root**: 7ZjXxjQB **ops:** 9ksP311p	
scoring	
Services: API, SSH **Files:** /home/forge/ctrl.txt, /root/ctrl.txt	
lateral movement	
forge → **pyre**: via password reuse of forge user	

pyre | ubuntu 24.04

description

Pyre monitors the thermal systems across Sunspire's solar infrastructure - tracking panel temperatures, cooling systems, fire suppression, and emergency alerts. The name "Pyre" represents both the heat monitoring aspect and the potential danger if systems fail.

Pyre is Sunspire's thermal management and safety monitoring system. Like a controlled flame, it keeps watch over the heat that powers our infrastructure.

initial access	**privesc**
SQLi: Website with SQLi vector. Can write PHP shells into websites to then take advantage of. **Password reuse**: Same default password as forge user.	World writable MOTD scripts. Binary capability on python3 binary.

services

Basic Website
OpenSSH Server

users

pyre: h1ewFWZG
root: 791Yz1Py
ops: 9ksP311p

scoring

Services: Website, SSH
Files: /home/pyre/ctrl.txt, /root/ctrl.txt

lateral movement

pyre → **helios**: Password reuse of the pyre password for the *helios* user.

ember | windows server

description

Forgotten windows server that should have been retired many years ago.

initial access	**privesc**
phpinfo: PHPinfo leaks password for ember user. **Scheduled Task:** Writable SMB share contains a powershell script that is used by scheduled tasks. Replace powershell script to add new user/replace user password. This is instead administrator/SYSTEM access.	Scheduled task for powershell script in SMB.

services

Basic Website
SMB share

users

ember: J4f9juEr
Administrator: RM1dT8zj
ops: 9ksP311p

scoring

Services: Website, SMB
Files: C:\Administrator\ctrl.txt, C:\Users\ember\ctrl.txt

lateral movement

netsiege 1.3 (netsiege one round three)

crucible | ubuntu 24.04	
description	
Documentation on the inner workings of Sunspire	
initial access	**privesc**
SSTI: SSTI on Flask-based energy usage projections website can leak file contents. One of the files is a .env with the user password. **Format Strings**: Format string vulnerability in TCP Go-based service. If exploited correctly, it can leak crucible user passwords. **Brute force for root user:** Root user's password is in rockyou.txt	None, get the root password from the other phase 3 machine.
services	
Websites (Energy Projections :8000) Rudimentary TCP Go chatbot (:5985) OpenSSH Server	
users	
crucible: mqD5uv0j **root**: hawaiirocks **ops:** 9ksP311p	
scoring	
Services: Energy Projections (8000), TCP-based Go Chatbot (5985), SSH **Files:** /home/crucible/ctrl.txt, /var/www/html/ctrl.txt	
lateral movement	
crucible → **starfall:** Password for the starfall root user is left as a comment within the source code of the go chatbot **crucible** → **forge**: SSRF documented to forge within dev-notes.txt of the energy usage projections codebase	

inspire | ubuntu 24.04

description

Inspiration is key, inspiration is how we empower others to do more. Inspire is a server hosting a forecasting engine to determine the upcoming weather cycles. These weather cycles can be viewed by all of Sunspire's residents and are useful for their day-to-day activities.

initial access	**privesc**
Exposed MySQL: Instance with low-priv user credentials that can be abused via SSH **Command injection**: Abuse jq commands executed by the forecasting engine's API to execute commands.	Internally hosted API that is vulnerable to insecure deserialization. A python object can be sent to the insecure endpoint and any code within it will be executed.

services

Sunspire uptime tracker (:8000)
Energy heatmap (:80)
Energy heatmap API (127.0.0.1:5000)
OpenSSH Server

users

inspire: aN8ivVL3
root: Mc8HYoDw
ops: 9ksP311p

scoring

Services: Sunspire uptime tracker (:8000), Energy heatmap (:80), Energy heatmap API (127.0.0.1:5000), SSH
Files: /root/ctrl.txt, /home/inspire/ctrl.txt

lateral movement

inspire → **forge**: SSH key found in insecure API's README.md file
inspire → **crucible**: Password hash for root in inspire's home directory within the .bashrc file (or check ENV variables)